# 第 22 章 云计算

## 0. 学习目标总览

教材给出本章七个学习目标：

1. 概述云计算的概念。
2. 列出并定义主要的云服务。
3. 列出并定义云部署模型。
4. 解释NIST云计算参考架构。
5. 理解与云计算相关的特殊安全问题。
6. 描述云安全即服务。
7. 理解云安全的OpenStack安全模块。

本章主线是从云计算模型出发，明确服务和部署责任，再把安全责任分配到云用户、云提供商及相关第三方：

```
云计算
  |-- 五个基本特征：网络接入 / 可伸缩 / 计量 / 自助 / 资源池化
  |-- 三种服务模型：SaaS / PaaS / IaaS
  |-- 四种部署模型：公有云 / 私有云 / 社区云 / 混合云
  |-- 云安全：风险识别、责任划分、数据与身份保护
  |-- SecaaS：把身份、数据、Web、邮件、入侵和网络安全作为云服务
  `-- OpenStack Keystone：身份、令牌、服务目录、策略
```

## 1. 学习目标 1：云计算的概念

### 1.1 NIST 定义与五个基本特征

NIST 将云计算定义为：通过网络对共享的可配置计算资源池进行无处不在、方便、按需的访问，并以很少的管理开销或服务提供者交互实现快速提供和释放。资源池包括网络、服务器、存储、应用和服务；云模型由五个基本特征、三个服务模型和四个部署模型组成。

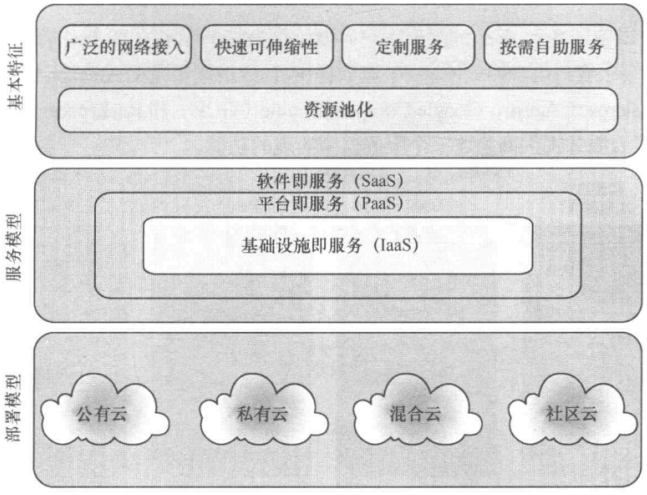



图 22.1　云计算元素

*图 22.1 云计算的基本特征、服务模型和部署模型*

| 特征 | 含义 |
| --- | --- |
| 广泛的网络接入 | 通过网络和标准机制提供功能，使手机、笔记本电脑、PDA 及其他软件客户端能够访问。 |
| 快速可伸缩性 | 根据服务需求快速扩展或释放资源，资源规模对用户而言可近似无限。 |
| 计量服务 | 按存储、处理、带宽或活跃账户等服务类型自动计量、监视、控制和报告资源使用。 |
| 按需自助服务 | 云服务消费者可以单方面获取服务器时间、网络存储等资源，无须逐次人工交互。 |
| 资源池化 | 提供商将物理和虚拟资源汇集，以多租户方式动态分配；消费者通常只指定较高层次的位置，不能控制具体设备。 |

这些特征共同形成云的弹性和经济性：资源不是企业永久拥有的 IT 组成，而是按需求取得、使用和释放的服务。

## 2. 学习目标 2：主要云服务模型

三个服务模型可视为逐层嵌套的选项：SaaS 建立在 PaaS 之上，PaaS 和 SaaS 又建立在 IaaS 提供的基础设施之上。

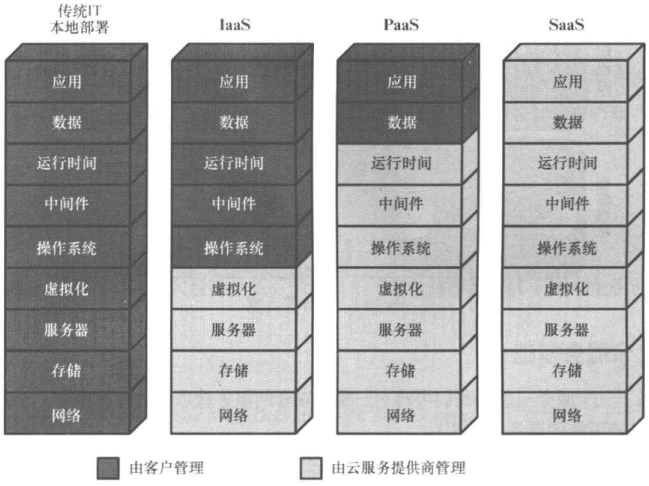



图 22.2　云服务模型中的职责分离

*图 22.2 三种云服务模型的职责分离*

| 模型 | 用户获得的能力 | 用户主要控制 | 提供商主要负责 | 典型例子 |
| --- | --- | --- | --- | --- |
| 软件即服务（SaaS） | 直接使用云中运行的应用软件。 | 应用的使用和部分数据配置。 | 基础设施、平台以及应用的部署、维护、升级和补丁。 | Gmail、Microsoft 365、Salesforce、WebEx。 |
| 平台即服务（PaaS） | 在云平台上开发、测试、部署和管理应用。 | 自己部署的应用及相关数据。 | 基础设施、运行环境、数据库、中间件和开发工具。 | Google App Engine、Heroku、Azure Cloud Services。 |
| 基础设施即服务（IaaS） | 使用虚拟机、存储、网络和其他基础计算资源部署任意软件。 | 操作系统、应用程序及部分网络组件（如主机防火墙）。 | 物理服务器、网络、存储和托管设施。 | Amazon EC2、Microsoft Azure、Google Compute Engine。 |

服务模型的核心差异是责任边界：从 SaaS 到 IaaS，消费者获得的控制逐渐增加，同时也承担更多配置和安全责任。

# 3. 学习目标 3：云部署模型

## 3.1 四种模型

| 模型 | 所有权和使用方式 | 主要优势 | 主要限制或风险 |
| --- | --- | --- | --- |
| 公有云 | 面向公众或大型行业，由提供商拥有和运营，多租户共享基础设施。 | 成本低、按使用付费、易于扩展、管理开销小。 | 服务等级和数据恢复保证可能较低；隐私与合规责任仍由消费者承担；租户隔离程度取决于提供商。 |
| 私有云 | 在企业内部实现，或由第三方用专用资源托管。 | 对数据位置、安全控制和资源共享有更强控制，安全性通常最高。 | 成本较高，可扩展性受企业资源限制。 |
| 社区云 | 具有共同需求的多个机构共享受限云资源，例如卫生保健机构。 | 可在满足法规和数据交换需求的同时分摊成本。 | 参与者较少，成本和资源规模介于公有云与私有云之间。 |
| 混合云 | 两个或多个独立的私有、社区或公有云通过标准化或专有技术连接。 | 敏感信息可留在私有区域，非敏感信息利用公有云的成本和弹性。 | 需要保证跨云的数据与应用可移植性以及安全链路。 |

典型属性比较如下：公有云的可扩展性最高、成本最低但性能和可靠性相对较低；私有云成本最高但安全性、性能和可靠性最好；社区云在多个机构间分摊成本；混合云兼顾较高扩展性、安全性和性能。

## 3.2 公有云与私有云配置

公有云中的企业资源与其他客户资源隔离，但可能共享同一物理硬件或虚拟化平台。私有云可以位于企业内部，也可以由云提供商使用不与其他客户共享的专用资源托管；远程用户通常通过 VPN 连接到企业安全边界。

# 4. 学习目标 4：NIST 云计算参考架构

NIST 云计算参考架构是讨论云服务“是什么”的通用高层概念模型，不是某个具体云系统的实现架构。它用于理解、分类和比较云服务，也支持对安全性、互操作性、可移植性及参考实现标准的分析。

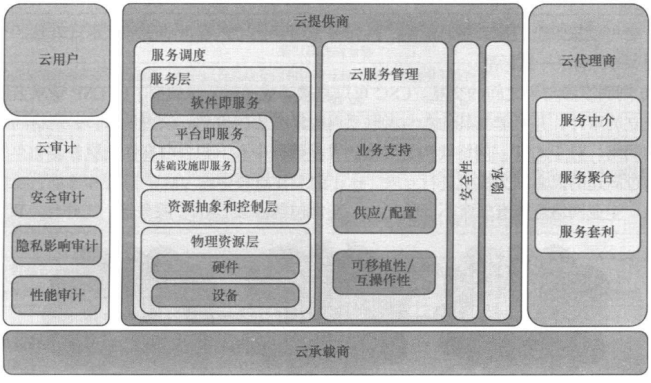



图 22.5　NIST 云计算参考架构

*图 22.5 NIST 云计算参考架构的角色与职责*

## 4.1 五个主要角色

| 角色 | 职责 |
| --- | --- |
| 云服务消费者（CS… | 与云服务提供商保持商业关系并使用云服务的个人或企业。 |
| 云服务提供商（CS… | 提供一个或多个云服务，管理相应的存储、处理设施和云接口。 |
| 云审计者 | 独立评估云服务、信息系统操作、性能以及安全性和隐私控制。 |
| 云经销商或云代理商 | 在 CSP 与云用户之间管理、组合或转售服务，并可提供身份管理、性能报告等增值服务。 |
| 云承载商 | 提供 CSC 与 CSP 之间的连接和传输，可按 SLA 要求提供专用安全连接。 |

云代理商的三类服务是：服务中介（增加身份管理、报告或安全功能）、服务聚合（组合多个云服务）和服务套利（根据需要灵活选择不同代理机构的服务）。

### 4.2 三类网络关注点

参考架构中的交互涉及三类网络：CSP 的数据中心网络关注虚拟机部署、迁移、负载平衡和可用性；企业网络包含 LAN、服务器、工作站和移动设备，关注性能、安全和管理；云承载商网络需要在适当 SLA 和安全保证下建立虚拟网络。

## 5. 学习目标 5：云计算的特殊安全问题

### 5.1 云安全的责任与治理

云计算并没有消除传统 IT 安全问题，还因多租户、资源共享、动态分配和控制权转移产生特殊风险。企业即使将资源、服务和应用的控制交给 CSP，仍必须对自身安全和隐私策略负责。

NIST 云安全指南要求从以下方面治理云环境：

| 方面 | 核心要求 |
| --- | --- |
| 管理 | 把云应用开发和服务使用纳入企业策略、程序、标准、审计和全生命周期监督。 |
| 合规性 | 审查数据位置、隐私、记录管理、电子发现和合同条款，确认满足法律法规。 |
| 可信性 | 保持对安全控制、数据所有权和系统安全状态的可见性，持续进行风险管理。 |
| 架构 | 理解 CSP 底层技术及其对整个系统生命周期和组件安全的影响。 |
| 身份及访问管理（IAM） | 保护身份验证、授权及其他 IAM 功能。 |
| 软件隔离 | 评估多租户虚拟化和逻辑隔离技术带来的风险。 |
| 数据保护 | 在静止、传输和使用时保护数据，并安全清理数据。 |
| 可用性 | 评估备份、恢复和灾难恢复合同，确保关键操作可及时恢复。 |
| 应急响应 | 明确企业与 CSP 的角色、透明响应流程和事件后的信息共享。 |

安全责任通常由三方共同承担：云用户负责应用级安全，CSP 负责物理设施和部分软件安全，中间软件层由双方共同保障。采用云服务前，企业需要调查 CSP 的安全能力、合同、SLA、数据位置、可审计性和退出机制。

### 5.2 STRIDE 威胁模型

STRIDE 是微软提出的蓄意攻击分类系统，六个字母分别代表：

| 类别 | 含义 | 对应安全控制 |
| --- | --- | --- |
| S：身份欺骗 | 使用他人的身份验证信息访问系统。 | 认证 |
| T：篡改数据 | 未授权修改存储或传输中的数据。 | 完整性 |
| R：抵赖 | 用户否认执行过某操作，系统无法证明。 | 不可抵赖 |
| I：信息泄露 | 信息被不应接触它的人读取或获取。 | 保密性 |

| 类别 | 含义 | 对应安全控制 |
| --- | --- | --- |
| D：拒绝服务 | 使有效用户无法获得服务。 | 可用性 |
| E：提升权限 | 非特权用户获得足以破坏系统的权限。 | 授权 |

## 5.3 十二类云安全威胁及对策

| 威胁 | 关键风险 | 教材强调的对策 |
| --- | --- | --- |
| 数据泄露 | 敏感数据被查看、窃取、删除或篡改；密钥丢失会放大后果。 | 控制访问；保护静止、传输和使用中的数据；客户端加密并由客户端掌握密钥。 |
| 弱身份、凭证和访问管理 | 身份验证、授权或用户配置文件不足。 | 建立可信 IAM、身份提供和可审计访问控制。 |
| 不安全的 API | API 被用于绕过认证、授权、加密或监控策略。 | 分析 CSP API 安全模型，使用强认证、访问控制和加密传输，理解依赖链。 |
| 系统漏洞 | 云基础设施操作系统和系统软件存在可利用缺陷。 | 风险管理、定期漏洞检测、补丁管理和人员培训。 |
| 账号劫持 | 窃取凭证后破坏云服务的保密性、完整性和可用性。 | 禁止共享凭证，采用强双因素认证，主动监测并理解 CSP 策略和 SLA。 |
| 恶意内部人员 | CSP 管理员等高权限角色滥用信任。 | 供应链评估、合同约束、透明管理和漏洞报告流程。 |
| 高级持续威胁（APT） | 攻击者长期隐蔽驻留，窃取高价值信息。 | 使用威胁情报发现目标、缩短检测时间并加快补救。 |
| 数据丢失 | 数据或备份被意外或恶意删除，造成永久丢失。 | 定期备份、地理冗余和提前备份。 |
| 尽职调查不足 | 迁移前没有评估 CSP 基础设施、认证、保护和灾难能力。 | 核实设施、合规认证、CSP 自身尽调和完整数据保护控制。 |
| 滥用及恶意使用云服务 | 攻击者利用易注册的云资源发起垃圾邮件、恶意代码或 DoS。 | 强化注册验证、监控支付欺诈、分析流量和公共黑名单。 |
| 拒绝服务 | CSP 的公共接口成为 DoS 目标，阻断 CSC 访问。 | 持续威胁情报和自动化保护核心云服务。 |
| 共享技术中的漏洞 | 多租户共享 CPU、GPU 等底层组件，隔离不足导致跨租户风险。 | 安全配置、变更监控、强认证和访问控制、及时修补、漏洞扫描与审计。 |

APT 的典型阶段是：背景研究、初始社会工程攻击、建立立足点、维持持久性、企业侦察、横向迁移、提升特权、收集并加密资料、提取数据和长期驻留。威胁情报可在通告前发现风险，也可在攻击发生后缩短发现和响应时间。

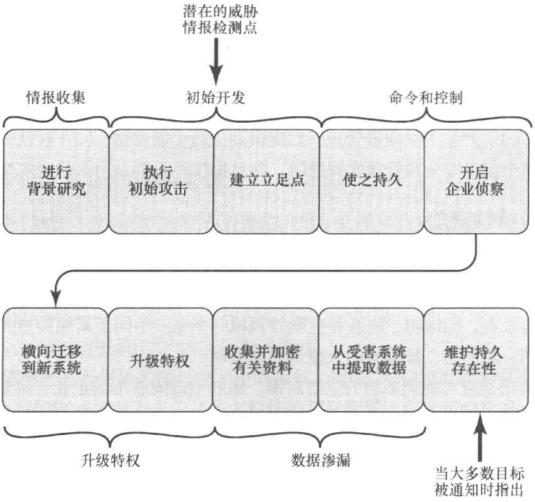



图 22.7　对抗高级持续威胁的威胁情报

*图 22.7 威胁情报帮助缩短 APT 的发现和补救时间*

## 6. 学习目标 6：云安全即服务

安全即服务（SecaaS）把一组安全责任交给服务提供者。在云环境中，SecaaS 通常是 CSP 的 SaaS 产品的一部分，可保护云基础设施、云软件或用户内部系统。

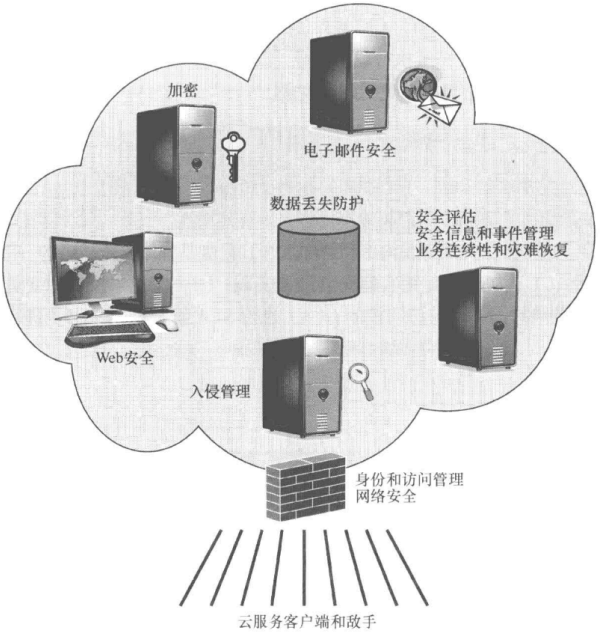



图 22.8　云安全即服务的元素

*图 22.8 云安全即服务的组成*

云安全联盟列出的 SecaaS 类别包括：

1. 身份和访问管理；
2. 数据丢失防护；
3. Web 安全；
4. 电子邮件安全；
5. 安全评估；
6. 入侵管理；
7. 安全信息和事件管理；
8. 加密；
9. 业务连续性和灾难恢复；
10. 网络安全。

| 服务 | 作用 |
| --- | --- |
| IAM | 管理身份验证、授权和访问权限。 |
| DLP | 监视、保护和验证静止、传输及使用中的数据。 |
| Web 安全 | 通过代理、设备或流量重定向实时阻止恶意软件，并可提供策略执行、备份、流量控制和 Web 访问控制。 |
| 电子邮件安全 | 控制入站和出站邮件，防御钓鱼和恶意附件，可统一实施签名和加密。 |
| 安全评估 | 由第三方审计云服务，CSP 可提供评估工具和接入点。 |
| 入侵管理 | 提供 IDS、IPS 及入侵响应；IPS 在 IDS 检测基础上增加阻断机制。 |
| SIEM | 聚合、关联和分析虚拟及真实网络、应用和系统的日志事件，产生实时报告和告警。 |
| 加密 | 保护云数据、邮件流量、网络管理信息和身份信息，同时涉及密钥管理和 VPN。 |
| 业务连续性与灾难恢复 | 通过冗余、故障转移、地理分布数据中心和备份保持服务弹性。 |
| 网络安全 | 提供边界防火墙、服务器防火墙和 DoS 防护等底层资源保护。 |

SecaaS 的价值在于利用服务提供者的规模和专业能力，但企业仍需确认数据控制、密钥管理、审计、SLA 和责任边界。

## 7. 学习目标 7：OpenStack 的 Keystone 安全模块

OpenStack 是支持多租户 IaaS 的开源云操作系统项目，由多个可独立使用又可组合的模块构成。其安全模块 Keystone 提供云基础设施共享的身份和访问控制服务。

### 7.1 Keystone 的四类共享服务

| 服务 | 作用 |
| --- | --- |
| 身份 | 保存用户身份信息，定义项目中的角色和权限，是 RBAC 的基础；支持用户名/口令、LDAP 和外部身份验证。 |
| 令牌 | 用户认证后获得令牌，其他 OpenStack 服务在操作期间用令牌向 Keystone 查询访问权限。 |
| 服务目录 | 注册 OpenStack 服务端点；客户端根据 Keystone 返回的目录确定要调用的端点。 |
| 策略 | 在各服务的策略文件中定义资源访问级别，管理员可修改策略以控制 API、卷容量或实例启动等权限。 |

### 7.2 Keystone 与 Nova、Glance、Swift 的交互

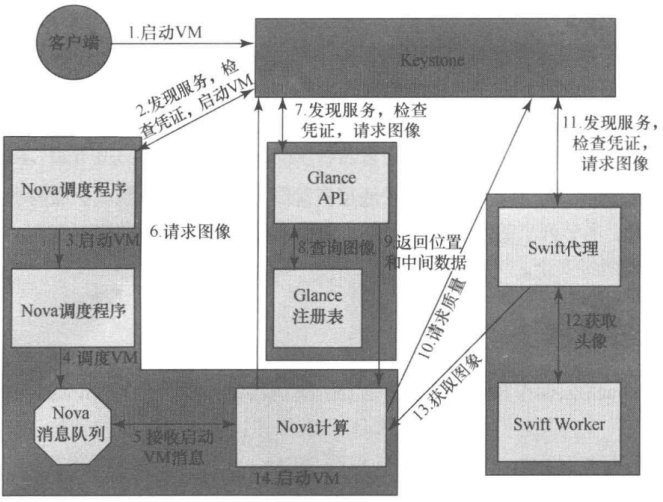



图 22.9　启动 OpenStack 中的虚拟机

*图 22.9 启动 OpenStack 虚拟机时 Keystone 与其他组件的交互*

- **Nova**：管理计算实例生命周期，负责按需生成、调度和报废虚拟机。
- **Glance**：通过 API 对虚拟机磁盘映像进行发现、注册和检索。
- **Swift**：提供冗余、可扩展的分布式对象存储，适合保存虚拟机映像、照片、邮件、备份和存档等静态数据。

典型启动流程是：客户端请求启动 VM，Nova 与 Keystone 发现服务并检查凭证；Nova 调度 VM，必要时向 Glance 请求映像；映像位置和中间数据返回后，Nova 向 Swift 请求并取得映像，最后启动 VM。Keystone 在各服务之间持续提供认证、令牌和端点发现。

## 本章关键术语整理

| 术语 | 核心含义 |
| --- | --- |
| 云计算 | 通过网络按需访问共享可配置计算资源池的模型。 |
| 资源池化 | 提供商汇集物理和虚拟资源并按多租户需求动态分配。 |
| SaaS | 直接使用云中运行和维护的应用软件。 |
| PaaS | 在云平台提供的运行环境和工具上开发、部署应用。 |
| IaaS | 使用虚拟机、存储、网络等基础资源部署任意软件。 |
| 公有云 | 面向公众、由提供商运营的多租户云。 |
| 私有云 | 为单个企业使用的内部或专用托管云。 |
| 社区云 | 由具有共同需求的多个机构共享的受限云。 |
| 混合云 | 通过技术连接的两个或多个不同部署模型的云。 |
| CSC | 云服务消费者，使用云服务的个人或企业。 |
| CSP | 云服务提供商，负责提供和运营云服务。 |
| 云审计者 | 独立评估云服务、安全和隐私控制的实体。 |
| 云承载商 | 提供 CSC 与 CSP 之间连接和传输的中介。 |
| STRIDE | 按身份欺骗、篡改、抵赖、泄露、拒绝服务和提升权限分类威胁的模型。 |
| SecaaS | 通过云提供身份、数据、Web、入侵、加密等安全服务。 |

| 术语 | 核心含义 |
| --- | --- |
| IAM | 身份验证、授权及访问权限管理。 |
| SIEM | 聚合、关联和分析日志与事件并产生告警的安全信息系统。 |
| Keystone | OpenStack 提供身份、令牌、服务目录和策略的安全模块。 |
| Nova | OpenStack 虚拟机计算和生命周期管理模块。 |
| Glance | OpenStack 虚拟机磁盘映像管理模块。 |
| Swift | OpenStack 分布式对象存储模块。 |

## 学习目标自检

1. 能否说明云计算的 NIST 定义及广泛网络接入、快速可伸缩性、计量、自助和资源池化五个特征？
2. 能否比较 SaaS、PaaS 和 IaaS 的用户能力、责任边界和典型用途？
3. 能否定义公有云、私有云、社区云和混合云，并比较它们的成本、安全性、扩展性和管理方式？
4. 能否说明 NIST 云计算参考架构的用途、五个主要角色及三类网络关注点？
5. 能否用责任划分和 STRIDE 模型分析数据泄露、IAM、API、APT、数据丢失和共享技术等云安全威胁？
6. 能否列出 SecaaS 的十类服务，并说明 DLP、Web 安全、入侵管理、SIEM、加密和灾难恢复的作用？
7. 能否解释 Keystone 的身份、令牌、服务目录和策略服务，以及它与 Nova、Glance、Swift 的协作？